

INTERNATIONAL
STANDARD

ISO/IEC
42001:2023

Edition 1
2023-12

Information technology — Artificial
intelligence — Management system



Reference number
ISO/IEC 42001:2023

© ISO 2024

전 문

ISO(국제표준화기구)와 IEC(국제전기기술위원회)는 전 세계 표준화를 위한 전문 시스템을 구성합니다. ISO 또는 IEC의 회원인 국가 기관들은 특정 기술 활동 분야를 다루기 위해 각 조직에 의해 설립된 기술 위원회를 통해 국제 표준 개발에 참여합니다. ISO와 IEC의 기술 위원회는 공통 관심 분야에서 협력하며, ISO 및 IEC와 협력 관계에 있는 기타 국제 기구, 정부 및 비정부 기구들도 이 작업에 참여합니다.

이 문서 개발에 사용된 절차와 향후 유지 관리에 사용될 절차는 ISO/IEC 지침 제1부에 설명되어 있습니다. 특히, 서로 다른 유형의 문서에 필요한 승인 기준의 차이를 주목해야 합니다. 이 문서는 ISO/IEC 지침 제2부의 편집 규칙에 따라 작성되었습니다.

(자세한 내용은 www.iso.org/directives

또는 www.iec.ch/members_experts/refdocs참조).

ISO와 IEC는 이 문서의 구현이 (특허) 사용을 포함할 가능성이 있음을 알립니다. ISO와 IEC는 해당 특허 권리의 증거, 유효성 또는 적용 가능성에 대해 입장을 취하지 않습니다. 이 문서 발행일 기준으로 ISO와 IEC는 이 문서를 구현하는 데 필요한 특허에 대한 통지를 받지 못했으나, 최신 정보는 www.iso.org/patents 및 <https://patents.iec.ch>에서 얻을 수 있음을 주의해야 합니다. ISO와 IEC는 이러한 특허 권리를 식별할 책임이 없습니다.

이 문서에서 사용된 상표명은 사용자에게 편의를 제공하기 위한 정보일 뿐, 보증을 의미하지 않습니다.

표준의 자발적 성격, ISO의 특정 용어와 평가 관련 의미에 대한 설명, 그리고 기술무역장벽(TBT)에 관한 세계무역기구(WTO) 원칙에 대한 ISO의 준수를 설명하는 문서는 www.iso.org/iso/foreword.html 에서 확인할 수 있습니다.

IEC와 관련해서는 www.iec.ch/understanding-standards를 참조하십시오.

이 문서는 ISO/IEC JTC 1, 정보 기술, SC 42 인공지능 분과위원회에 의해 작성되었습니다.

이 문서에 대한 피드백이나 질문은 사용자의 국가 표준 기관으로 보내야 합니다. 이러한 기관의 전체 목록은

www.iso.org/members.html ,

www.iec.ch/national-committees에서 확인할 수 있습니다.

소 개

인공지능(AI)은 정보 기술을 활용하는 모든 분야에서 점점 더 널리 적용되고 있으며, 주요 경제적 동인 중 하나로 자리 잡을 것으로 예상됩니다. 이 같은 추세에의 결과로 인해 향후 몇 년간 특정 AI 응용이 사회적 도전을 야기할 수 있습니다.

이 문서는 AI 시스템을 책임감 있게 사용하는 것(예: AI를 활용한 제품이나 서비스를 개발, 모니터링, 제공하는 역할을 수행하는 것)을 위해 조직이 AI 시스템과 관련하여 역할을 충실히 이행할 수 있도록 지원하는 것을 목적으로 합니다. AI는 잠재적으로 다음과 같은 구체적인 고려 사항을 제기합니다:

- 비투명하거나 설명이 어려운 방식으로 자동 결정을 내리는 데 AI를 사용할 경우, 기존 IT 시스템 관리와는 별개의 관리가 필요할 수 있습니다.
- 사람의 코딩 논리가 아닌 데이터 분석, 통찰력 및 머신러닝을 사용하여 시스템을 설계함으로써 AI 시스템의 응용 기회를 확대하고 이러한 시스템의 개발, 정당화, 배포 방식을 변화시킵니다.
- 지속 학습을 수행하는 AI 시스템은 사용 중에 동작을 변화시키며, 이러한 변화 속에서도 AI 시스템이 책임감 있게 사용되도록 특별한 고려가 필요합니다.

이 문서는 조직의 맥락에서 AI 경영 시스템을 수립, 구현, 유지, 지속적으로 개선하기 위한 요건을 제공합니다. 조직은 AI의 고유한 특성에 초점을 맞춰 이러한 요건을 적용하도록 기대됩니다. AI의 지속 학습 및 개선 능력, 투명성 및 설명 가능성 부족 등의 특정 특징은 전통적인 방식과 비교할 때 추가적인 우려가 있을 경우 다양한 보호 장치를 요구할 수 있습니다. AI 경영 시스템의 도입은 기존 관리 구조를 확장하는 조직의 전략적 결정입니다.

조직의 필요와 목표, 프로세스, 규모와 구조, 다양한 이해관계자의 기대는 AI 경영 시스템의 수립 및 구현에 영향을 미칩니다. AI 경영 시스템 수립과 구현에 영향을 미치는 또 다른 요소는 다양한 AI 사용 사례와 거버넌스 메커니즘과 혁신 사이의 적절한 균형을 유지할 필요성입니다. 조직은 이러한 요건을 위험 기반 접근

법을 사용하여 적용할 수 있으며, 이를 통해 조직의 범위 내 특정 AI 사용 사례, 서비스 또는 제품에 대해 적절한 수준의 통제가 이루어지도록 할 수 있습니다. 이러한 모든 영향 요인은 시간이 지남에 따라 변화하고 재검토될 것으로 기대됩니다.

AI 경영 시스템은 조직의 프로세스와 전체 관리 구조와 통합되어야 합니다. AI와 관련된 특정 이슈는 프로세스, 정보 시스템 및 통제의 설계에서 고려되어야 합니다. 중요한 관리 프로세스의 예는 다음과 같습니다:

- 조직 목표의 결정, 이해관계자의 참여, 조직 정책;
- 위험과 기회의 관리;
- AI 시스템의 보안, 안전, 공정성, 투명성, 데이터 품질 및 생애 주기 전반의 품질 등 AI 시스템 신뢰성과 관련된 문제 관리 프로세스;
- 조직을 위해 AI 시스템을 제공하거나 개발하는 공급업체, 파트너 및 제3자의 관리 프로세스.

이 문서는 이러한 프로세스를 지원하기 위한 적절한 통제 수단을 배포하기 위한 지침을 제공합니다.

이 문서는 관리 프로세스에 대한 구체적인 지침을 포함합니다. 조직은 일반적으로 인정되는 프레임워크, 다른 국제 표준 및 자체 경험을 결합하여 범위 내의 특정 AI 사용 사례, 제품 또는 서비스에 적합한 위험 관리, 생애 주기 관리 및 데이터 품질 관리와 같은 중요한 프로세스를 구현할 수 있습니다.

이 문서의 요구 사항을 준수하는 조직은 AI 시스템과 관련한 역할에 대한 책임과 책무성을 증명할 수 있는 근거를 생성할 수 있습니다.

이 문서에 제시된 요구 사항의 순서는 중요도를 반영하거나 구현 순서를 암시하지 않으며, 참조 목적으로 열거된 것일 뿐입니다.

다른 경영 시스템 표준과의 호환성

이 문서는 경영 시스템 표준(MSS) 간의 일관성을 높이기 위해 개발된 통합 구조(동일한 조항 번호, 조항 제목, 텍스트 및 공통 용어와 핵심 정의)를 적용합니다. AI 경영 시스템은 조직에서 AI를 사용할 때 발생하는 문제와 위험을 관리하는 데 필요한 특정 요

구 사항을 제공합니다. 이러한 통합 접근 방식은 다른 경영 시스템 표준(예: 품질, 안전, 보안 및 프라이버시 관련 표준)과의 일관성과 구현을 용이하게 합니다.

정보 기술 — 인공지능 — 경영 시스템

1 범위

이 문서는 조직의 맥락에서 AI(인공지능) 경영 시스템을 수립, 구현, 유지 및 지속적으로 개선하기 위한 요구 사항을 지정하고 지침을 제공합니다.

이 문서는 AI 시스템을 활용한 제품이나 서비스를 제공하거나 사용하는 조직을 위해 작성되었습니다. 조직이 목표를 달성하는 과정에서 AI 시스템을 책임감 있게 개발, 제공 또는 사용할 수 있도록 돕고, 관련 이해관계자의 요구 사항과 기대에 부합하는 의무를 충족하는 데 목적이 있습니다.

이 문서는 AI 시스템을 활용한 제품이나 서비스를 제공하거나 사용하는 모든 조직에 적용되며, 조직의 규모, 유형 및 성격에 관계없이 적용 가능합니다.

2 인용 표준

다음 문서들은 본 문서에서 일부 또는 전체 내용이 요구 사항으로 참조됩니다. 연도 표기가 있는 인용 문서는 명시된 판만 적용되며, 연도 표기가 없는 경우 최신 판본(수정 사항 포함)이 적용됩니다.

- ISO/IEC 22989:2022, 정보 기술 — 인공지능 — 인공지능 개념 및 용어

3 용어 및 정의

본 문서의 목적상, ISO/IEC 22989에 명시된 용어 및 정의가 적용됩니다.

ISO와 IEC는 표준화에 사용되는 용어 데이터베이스를 다음 사이트에서 제공합니다:

- ISO 온라인 브라우징 플랫폼: <https://www.iso.org/obp>
- IEC Electropedia: <https://www.electropedia.org/>

3.1 조직 (organization)

자신의 목표(3.6)를 달성하기 위한 기능, 책임, 권한 및 관계를

가진 개인 또는 사람들의 집단

- 참고 1: 조직의 개념은 개인 사업자, 회사, 법인, 기업, 권한 기관, 파트너십, 자선 단체, 기관 또는 이들의 일부분이나 조합을 포함하며, 법인 여부와 관계없이 공공 또는 민간을 모두 포함합니다.
- 참고 2: 조직이 더 큰 실체의 일부일 경우, “조직”이라는 용어는 AI 경영 시스템(3.4)의 범위 내에 있는 더 큰 실체의 일부만을 지칭합니다.

3.2 이해관계자 (interested party)

결정이나 활동에 영향을 미치거나, 영향을 받을 수 있거나, 영향을 받는다고 인식하는 개인 또는 조직(3.1)

- 참고: AI의 이해관계자 개요는 ISO/IEC 22989:2022의 5.19에 제공됩니다.

3.3 최고 경영진 (top management)

조직(3.1)을 최고 수준에서 지시하고 통제하는 개인 또는 사람들의 집단

- 참고 1: 최고 경영진은 조직 내에서 권한을 위임하고 자원을 제공할 수 있는 권한을 가집니다.
- 참고 2: 경영 시스템(3.4)의 범위가 조직의 일부만을 포함하는 경우, 최고 경영진은 조직의 그 부분을 지시하고 통제하는 사람들을 의미합니다.

3.4 경영 시스템 (management system)

정책(3.5)과 목표(3.6)를 수립하고 해당 목표를 달성하기 위한 프로세스(3.8)를 포함하는, 조직(3.1)의 상호 관련되거나 상호 작용하는 요소들의 집합

- 참고 1: 경영 시스템은 단일 분야 또는 여러 분야를 다룰 수 있습니다.
- 참고 2: 경영 시스템 요소는 조직의 구조, 역할과 책임, 계획 및 운영을 포함합니다.

3.5 정책 (policy)

조직(3.1)의 의도와 방향이 최고 경영진(3.3)에 의해 공식적으로 표현된 것

3.6 목표 (objective)

달성해야 할 결과

- 참고 1: 목표는 전략적, 기술적 또는 운영적일 수 있습니다.
- 참고 2: 목표는 재무, 건강 및 안전, 환경 등 다양한 분야와 관련될 수 있으며, 예를 들어, 조직 전체 또는 특정 프로젝트, 제품 또는 프로세스(3.8)와 관련될 수 있습니다.
- 참고 3: 목표는 의도된 결과, 목적, 운영 기준, AI 목표 등 다른 방식으로 표현될 수 있으며, 비슷한 의미의 다른 용어(예: 목적, 목표 또는 타겟)를 사용할 수 있습니다.
- 참고 4: AI 경영 시스템(3.4)에서는 조직(3.1)이 AI 정책(3.5)에 따라 AI 목표를 설정하여 특정 결과를 달성합니다.

3.7 위험 (risk)

불확실성의 영향

- 참고 1: 영향은 예상에서의 편차로, 긍정적일 수도 부정적일 수도 있습니다.
- 참고 2: 불확실성은 사건, 그 결과 또는 발생 가능성에 대한 정보가 부분적으로 부족한 상태를 의미합니다.
- 참고 3: 위험은 잠재적인 사건(ISO Guide 73에서 정의)과 결과(ISO Guide 73에서 정의)를 참조하여 설명되거나 이들의 조합으로 설명됩니다.
- 참고 4: 위험은 종종 사건의 결과(상황 변화 포함)와 발생 가능성의 조합으로 표현됩니다.

3.8 프로세스 (process)

입력을 사용하거나 변환하여 결과를 도출하는 상호 관련되거나 상호 작용하는 활동들의 집합

- 참고 1: 프로세스의 결과가 출력, 제품 또는 서비스라고

불리는지는 참조의 맥락에 따라 다릅니다.

3.9 역량 (competence)

의도한 결과를 달성하기 위해 지식과 기술을 적용할 수 있는 능력

3.10 문서화된 정보 (documented information)

조직(3.1)에 의해 통제되고 유지되어야 하는 정보 및 그 정보가 포함된 매체

- 참고 1: 문서화된 정보는 어떤 형식이나 매체로든, 어떤 출처에서든 존재할 수 있습니다.
- 참고 2: 문서화된 정보는 다음을 참조할 수 있습니다:
 - 경영 시스템(3.4), 관련 프로세스(3.8) 포함;
 - 조직 운영을 위해 생성된 정보(문서);
 - 달성된 결과의 증거(기록).

3.11 성과 (performance)

측정 가능한 결과

- 참고 1: 성과는 정량적 또는 정성적 결과와 관련될 수 있습니다.
- 참고 2: 성과는 활동, 프로세스(3.8), 제품, 서비스, 시스템 또는 조직(3.1) 관리와 관련될 수 있습니다.
- 참고 3: 이 문서의 맥락에서 성과는 AI 시스템을 사용하여 달성된 결과와 AI 경영 시스템(3.4)과 관련된 결과를 모두 의미합니다. 용어의 올바른 해석은 사용 맥락에서 명확해집니다.

3.12 지속적 개선 (continual improvement)

성과(3.11)를 향상시키기 위한 반복 활동

3.13 효과성 (effectiveness)

계획된 활동이 실현되고 계획된 결과가 달성되는 정도

3.14 요구사항 (requirement)

명시되었거나 일반적으로 암시되거나 의무적인 필요 또는 기대

- 참고 1: "일반적으로 암시됨"이란 해당 필요 또는 기대가 조직(3.1)과 이해관계자(3.2)에 의해 관습 또는 일반적인 관행으로 암시됨을 의미합니다.
- 참고 2: 특정 요구사항은 문서화된 정보(3.10)에 명시된 것과 같은 명시적 요구사항을 의미합니다.

3.15 적합성 (conformity)

요구사항(3.14)의 충족

3.16 부적합 (nonconformity)

요구사항(3.14)을 충족하지 못함

3.17 시정 조치 (corrective action)

부적합(3.16)의 원인을 제거하고 재발을 방지하기 위한 조치

3.18 감사 (audit)

감사 기준이 충족되는 정도를 객관적으로 평가하기 위해 증거를 얻고 평가하는 체계적이고 독립적인 프로세스(3.8)

- 참고 1: 감사는 내부 감사(제1자) 또는 외부 감사(제2자 또는 제3자)가 될 수 있으며, 두 개 이상의 분야를 결합한 통합 감사가 될 수 있습니다.
- 참고 2: 내부 감사는 조직(3.1) 자체 또는 조직을 대신한 외부 기관에 의해 수행됩니다.
- 참고 3: "감사 증거"와 "감사 기준"은 ISO 19011에 정의되어 있습니다.

3.19 측정 (measurement)

값을 결정하기 위한 프로세스(3.8)

3.20 모니터링 (monitoring)

시스템, 프로세스(3.8) 또는 활동의 상태를 확인하는 것

- 참고 1: 상태를 결정하기 위해 검사, 감독 또는 면밀한 관찰이 필요할 수 있습니다.

3.21 통제 (control)

<위험>을 유지하거나 수정하는 조치(3.7)

- 참고 1: 통제는 위험을 유지하거나 수정하는 모든 프로세스, 정책, 장치, 관행 또는 기타 조건 및/또는 행동을 포함하지만 이에 국한되지 않습니다.
- 참고 2: 통제가 항상 의도된 또는 가정된 수정 효과를 발휘하지 않을 수도 있습니다. [출처: ISO 31000:2018, 3.8, 수정됨 — <위험>을 응용 영역으로 추가함]

3.22 관리 기관 (governing body)

조직의 성과와 적합성에 대해 책임을 지는 개인 또는 사람들의 집단

- 참고 1: 모든 조직이, 특히 소규모 조직이, 최고 경영진과 별도의 관리 기관을 가지고 있는 것은 아닙니다.
- 참고 2: 관리 기관에는 이사회, 이사회의 위원회, 감독 이사회, 신탁 관리자 또는 감독관을 포함하되 이에 국한되지 않습니다.

[출처: ISO/IEC 38500:2015, 2.9, 수정됨 — 참고 사항 추가됨]

3.23 정보 보안 (information security)

정보의 기밀성, 무결성 및 가용성의 보존

- 참고 1: 진위성, 책임성, 부인 방지 및 신뢰성과 같은 기타 속성도 포함될 수 있습니다.

[출처: ISO/IEC 27000:2018, 3.28]

3.24 AI 시스템 영향 평가 (AI system impact assessment)

인공지능을 활용한 제품이나 서비스를 개발, 제공 또는 사용하는 조직이 개인, 개인 집단 또는 사회에 미치는 영향을 식별, 평가 및 해결하는 공식적이고 문서화된 프로세스

3.25 데이터 품질 (data quality)

특정 상황에서 데이터가 조직의 데이터 요구 사항을 충족하는 특성

[출처: ISO/IEC 5259-1:—1), 3.4]

3.26 적용성 선언서 (statement of applicability)

모든 필요한 통제(3.23)와 통제 포함 또는 제외에 대한 정당성을 문서화한 것

- 참고 1: 조직은 부록 A에 나열된 모든 통제를 요구하지 않을 수도 있으며, 조직 자체가 추가적으로 설정한 통제로 목록을 초과할 수도 있습니다.
- 참고 2: 모든 확인된 위험은 본 문서의 요구 사항에 따라 조직이 문서화해야 합니다. 확인된 모든 위험과 이를 해결하기 위해 수립된 위험 관리 조치(통제)는 적용성 선언서에 반영되어야 합니다.

4 조직의 상황

4.1 조직과 상황 이해

조직은 AI 경영 시스템의 목적과 관련이 있으며, 시스템이 의도한 결과를 달성하는 능력에 영향을 미치는 외부 및 내부 문제를 결정해야 합니다.

조직은 기후 변화가 관련 이슈인지 여부를 판단해야 합니다.

조직은 조직이 개발, 제공 또는 사용하는 AI 시스템의 의도된 목적을 고려해야 합니다. 조직은 이러한 AI 시스템과 관련한 역할을 결정해야 합니다.

- 참고 1: 조직과 그 상황을 이해하기 위해, 조직이 AI 시스템과 관련하여 수행하는 역할을 결정하는 것이 도움이 될 수 있습니다. 이러한 역할에는 다음이 포함될 수 있으나 이에 국한되지 않습니다:

- AI 플랫폼 제공자, AI 제품 또는 서비스 제공자를 포함한 AI 제공자;

- AI 개발자, AI 설계자, AI 운영자, AI 테스터 및 평가자, AI 배포자, 인간 요소 전문가, 도메인 전문가, AI 영향 평가자, 구매자, AI 거버넌스 및 감독 전문가를 포함한 AI 생산자;

- AI 사용자 포함 AI 고객;

- AI 시스템 통합자 및 데이터 제공자를 포함한 AI 파트너;

- 데이터 주체 및 기타 주체 포함 AI 주체;

- 정책 결정자 및 규제 기관을 포함한 관련 기관.

ISO/IEC 22989에서 이러한 역할에 대한 자세한 설명이 제공됩니다. 또한, 이러한 역할의 유형과 AI 시스템 생애 주기와의 관계는 NIST AI 위험 관리 프레임워크에서 설명됩니다. 조직의 역할은 이 문서의 요구 사항 및 통제의 적용 가능성 및 적용 범위를 결정할 수 있습니다.

- 참고 2: 이 조항에서 다뤄야 하는 외부 및 내부 문제는 조직의 역할 및 관할 구역에 따라 달라질 수 있으며, 이는 AI 경영 시스템의 의도한 결과를 달성하는 능력에 영향을 미칩니다. 이러한 문제는 다음을 포함할 수 있으나 이에 국한되지 않습니다:

a) 외부 상황과 관련된 고려사항:

1. AI의 금지된 사용을 포함한 관련 법적 요구 사항;
2. AI 시스템의 개발 및 사용에 있어 법적 요구 사항의 해석이나 시행에 영향을 미치는 규제 기관의 정책, 지침 및 결정;
3. AI 시스템의 의도된 목적과 사용에 따른 인센티브 또는 결과;
4. AI 개발 및 사용에 대한 문화, 전통, 가치, 규범 및 윤리;
5. AI 시스템을 사용하는 신제품 및 서비스와 관련된 경쟁 환경과 동향;

b) 내부 상황과 관련된 고려사항:

6. 조직의 상황, 거버넌스, 목표(6.2 참조), 정책 및 절차;
7. 계약상의 의무;
8. 개발 또는 사용될 AI 시스템의 의도된 목적.

참고 3: 역할 결정은 조직이 처리하는 데이터 범주와 관련된 의무(예: 개인 식별 정보(PII) 처리 시 PII 프로세서 또는 PII 컨트롤러 역할)를 기반으로 형성될 수 있습니다. PII 및 관련 역할에 대해서는 ISO/IEC 29100을 참조하십시오. 역할은 AI 시스템에 특정한 법적 요구 사항에 의해 영향을 받을 수도 있습니다.

4.2 이해관계자의 요구와 기대 이해

조직은 다음을 결정해야 합니다:

- AI 경영 시스템과 관련된 이해관계자들;
- 이러한 이해관계자들의 관련 요구사항;
- AI 경영 시스템을 통해 충족할 이러한 요구사항 중 어떤 것들.

참고: 관련 이해관계자들은 기후 변화와 관련된 요구사항을 가질 수 있습니다.

4.3 AI 경영 시스템의 범위 결정

조직은 AI 경영 시스템의 경계와 적용 가능성을 결정하여 그 범위를 수립해야 합니다.

이 범위를 결정할 때, 조직은 다음을 고려해야 합니다:

- 4.1에 언급된 외부 및 내부 문제;
- 4.2에 언급된 요구사항.

범위는 문서화된 정보로 제공되어야 합니다.

AI 경영 시스템의 범위는 이 문서의 요구 사항, AI 경영 시스템의 리더십, 계획, 지원, 운영, 성과, 평가, 개선, 통제 및 목표와 관련하여 조직의 활동을 결정해야 합니다.

4.4 AI 경영 시스템

조직은 이 문서의 요구 사항에 따라 필요한 프로세스와 그 상호작용을 포함하여 AI 경영 시스템을 수립, 구현, 유지, 지속적으로 개선하고 문서화해야 합니다.

5 리더십

5.1 리더십과 헌신

최고 경영진은 AI 경영 시스템에 대한 리더십과 헌신을 다음과 같이 입증해야 합니다:

- AI 정책(5.2 참조) 및 AI 목표(6.2 참조)를 수립하고 조직의 전략적 방향과 일치하도록 보장;
- AI 경영 시스템 요구 사항을 조직의 비즈니스 프로세스에 통합하도록 보장;
- AI 경영 시스템에 필요한 자원을 확보하도록 보장;
- 효과적인 AI 관리의 중요성과 AI 경영 시스템 요구 사항 준수의 중요성을 소통;
- AI 경영 시스템이 의도된 결과를 달성하도록 보장;
- AI 경영 시스템의 효과성에 기여할 수 있도록 인력을 지시하고 지원;
- 지속적 개선을 촉진;
- 관련 역할이 책임 영역에 맞는 리더십을 발휘하도록 지원.

참고 1: 이 문서에서 "비즈니스"는 조직의 존재 목적에 핵심적인 활동을 넓게 해석할 수 있습니다.

참고 2: 조직 내에서 AI 시스템의 사용, 개발 및 관리에 책임 있는 접근 방식을 장려하고 모범을 보이는 문화 조성은 최고 경영진의 헌신과 리더십을 보여줄 수 있는 중요한 요소입니다. 이러한 책임 있는 접근 방식에 대한 인식과 준수는 리더십을 통해 AI 경영 시스템의 성공을 촉진할 수 있습니다.

5.2 AI 정책

최고 경영진은 다음과 같은 AI 정책을 수립해야 합니다:

- a) 조직의 목적에 적합한 정책;
- b) AI 목표(6.2 참조)를 설정하기 위한 프레임워크 제공;
- c) 적용 가능한 요구 사항을 충족하겠다는 약속 포함;
- d) AI 경영 시스템의 지속적 개선에 대한 약속 포함.

AI 정책은 다음과 같이 해야 합니다:

- 문서화된 정보로 제공;

- 다른 조직 정책과 관련된 부분을 참조;
- 조직 내에 전달;
- 적절히 이해관계자에게 제공.

AI 정책 수립을 위한 통제 목표와 통제 사항은 표 A.1의 A.2에 제공됩니다. 이러한 통제 사항의 구현 지침은 B.2에 제공됩니다.

참고: 조직이 AI 정책을 개발할 때 고려할 사항은 ISO/IEC 38507에 제공됩니다.

5.3 역할, 책임 및 권한

최고 경영진은 관련 역할에 대한 책임과 권한이 조직 내에서 할당되고 전달되도록 해야 합니다.

최고 경영진은 다음에 대한 책임과 권한을 할당해야 합니다:

- a) AI 경영 시스템이 이 문서의 요구 사항에 부합함을 보장;
- b) AI 경영 시스템의 성과를 최고 경영진에게 보고.

참고: 역할과 책임을 정의하고 할당하는 통제는 표 A.1의 A.3.2에 제공됩니다. 이 통제에 대한 구현 지침은 B.3.2에 제공됩니다.

6 계획

6.1 위험 및 기회에 대한 조치

6.1.1 일반

AI 경영 시스템을 계획할 때, 조직은 4.1에서 언급된 문제와 4.2에서 언급된 요구 사항을 고려하여 다음을 보장하기 위해 해결해야 할 위험과 기회를 결정해야 합니다:

- AI 경영 시스템이 의도된 결과를 달성할 수 있도록 보장;
- 바람직하지 않은 영향을 방지하거나 감소;
- 지속적인 개선을 달성.

조직은 다음을 지원하는 AI 위험 기준을 수립하고 유지해야 합니다:

- 수용 가능한 위험과 수용할 수 없는 위험을 구분;
- AI 위험 평가 수행;
- AI 위험 처리 수행;
- AI 위험 영향 평가.

참고 1: 조직이 추구하거나 유지하려는 위험의 양과 유형을 결정하는 고려 사항은 ISO/IEC 38507 및 ISO/IEC 23894에 제공됩니다.

조직은 다음에 따라 위험과 기회를 결정해야 합니다:

- AI 시스템의 도메인 및 응용 분야의 맥락;
- 의도된 사용 목적;
- 4.1에서 설명된 외부 및 내부 상황.

참고 2: 하나 이상의 AI 시스템이 AI 경영 시스템의 범위에 포함될 수 있습니다. 이 경우, 기회와 사용 목적의 결정은 각 AI 시스템 또는 AI 시스템 그룹에 대해 수행됩니다.

조직은 다음을 계획해야 합니다:

a) 이러한 위험과 기회를 해결하기 위한 조치;

b) 다음과 같은 방법으로:

1. 이러한 조치를 AI 경영 시스템 프로세스에 통합하고 구현하는 방법;
2. 이러한 조치의 효과를 평가하는 방법.

조직은 AI 위험과 AI 기회를 식별하고 해결하기 위해 취한 조치에 대한 문서화된 정보를 보유해야 합니다.

참고 3: AI 제품, 시스템 및 서비스를 개발, 제공 또는 사용하는 조직을 위한 위험 관리 구현 방법에 대한 지침은 ISO/IEC 23894에 제공됩니다.

참고 4: 조직의 상황과 활동은 조직의 위험 관리 활동에 영향을 미칠 수 있습니다.

참고 5: 위험의 정의 방식과 위험 관리를 구상하는 방식은 분야와 산업에 따라 다를 수 있습니다. 3.7에서 정의한 위험은 부록 D에 언급된 분야와 같이 어떤 분야에도 적용할 수 있는 광범위한 위험 비전을 허용합니다. 위험 평가의 일환으로, 조직은 우선 조직의 맥락에 맞는 위험 비전을 채택해야 합니다. 여기에는 AI 시스템이 개발되고 사용되는 분야에서 사용되는 정의를 통해 위험에 접근하는 것도 포함될 수 있으며, 예를 들어 ISO/IEC Guide 51의 정의가 사용될 수 있습니다.

6.1.2 AI 위험 평가

조직은 다음과 같은 AI 위험 평가 프로세스를 정의하고 수립해야 합니다:

a) AI 정책(5.2 참조) 및 AI 목표(6.2 참조)에 따라 정보를 제공하고 일치하도록 구성;

참고: 6.1.2 d) 1)의 일부로 결과를 평가할 때, 조직은 6.1.4에 명시된 AI 시스템 영향 평가를 활용할 수 있습니다.

b) 반복적인 AI 위험 평가가 일관성 있고, 유효하며 비교 가능한 결과를 도출할 수 있도록 설계;

c) AI 목표 달성을 돕거나 방해하는 위험을 식별;

d) AI 위험을 분석하여:

1. 식별된 위험이 발생할 경우 조직, 개인 및 사회에 미칠 수 있는 잠재적 결과를 평가;
2. 적용 가능한 경우, 식별된 위험의 현실적인 발생 가능성을 평가;
3. 위험 수준을 결정;

e) AI 위험을 평가하여:

4. 위험 분석 결과를 위험 기준(6.1.1 참조)과 비교;
5. 위험 처리의 우선 순위를 정하기 위해 평가된 위험을 우

선시킴.

조직은 AI 위험 평가 프로세스에 대한 문서화된 정보를 보유해야 합니다.

6.1.3 AI 위험 처리

위험 평가 결과를 고려하여 조직은 다음을 위해 AI 위험 처리 프로세스를 정의해야 합니다:

- a) 적절한 AI 위험 처리 옵션을 선택;
- b) 선택한 AI 위험 처리 옵션을 구현하는 데 필요한 모든 통제를 결정하고, 부록 A의 통제와 비교하여 필요한 통제가 누락되지 않았는지 확인;

참고 1: 부록 A는 조직 목표를 달성하고 AI 시스템의 설계 및 사용과 관련된 위험을 해결하기 위한 참조 통제를 제공합니다.

- c) AI 위험 처리 옵션 구현과 관련된 부록 A의 통제를 고려;
- d) 모든 위험 처리 옵션을 구현하기 위해 부록 A에 나열된 것 외에 추가 통제가 필요한지 확인;
- e) b) 및 c)에서 결정한 통제 구현에 대한 부록 B의 지침을 고려;

참고 2: 통제 목표는 선택한 통제에 암묵적으로 포함됩니다. 조직은 부록 A에서 적절한 통제 목표와 통제 세트를 선택할 수 있습니다. 부록 A의 통제는 포괄적이지 않으며 추가적인 통제 목표와 통제가 필요할 수 있습니다. 부록 A 이외의 통제가 필요할 경우, 조직은 이러한 통제를 설계하거나 기존 출처에서 가져올 수 있습니다. AI 위험 관리는 필요한 경우 다른 경영 시스템에 통합될 수 있습니다.

- f) 필요한 통제를 포함한 적용성 선언서를 작성하고 통제의 포함 및 제외에 대한 정당성을 제공. 제외의 정당성에는 통제가 위험 평가에 의해 불필요하다고 간주되거나, 관련 외부 요구 사항에 의해 요구되지 않거나 예외가 적용되는 경우를 포함할 수 있습니다.

참고 3: 조직은 부록 A에 나열된 것이든 조직 자체에서 수립한 것이든, 일반적이거나 특정 AI 시스템에 대해 제외된 통제 목표에 대한 문서화된 정당성을 제공할 수 있습니다.

- g) AI 위험 처리 계획을 수립.

조직은 지정된 경영진의 승인과 잔여 AI 위험 수용에 대한 승인을 AI 위험 처리 계획에 대해 받아야 합니다. 필요한 통제는 다음과 같아야 합니다:

- 6.2의 목표와 일치;
- 문서화된 정보로 제공;
- 조직 내에 전달;
- 적절히 이해관계자에게 제공.

조직은 AI 위험 처리 프로세스에 대한 문서화된 정보를 보유해야 합니다.

6.1.4 AI 시스템 영향 평가

조직은 AI 시스템의 개발, 제공 또는 사용이 개인 또는 개인 집단, 또는 사회에 미칠 수 있는 잠재적 영향을 평가하는 프로세스를 정의해야 합니다.

AI 시스템 영향 평가는 AI 시스템의 배포, 의도된 사용 및 예측 가능한 오용이 개인 또는 개인 집단, 또는 사회에 미칠 수 있는 잠재적 영향을 결정해야 합니다.

AI 시스템 영향 평가는 AI 시스템이 배포되는 특정 기술적 및 사회적 맥락과 적용 가능한 관할 구역을 고려해야 합니다.

AI 시스템 영향 평가의 결과는 문서화되어야 합니다. 필요에 따라, 시스템 영향 평가의 결과는 조직에서 정의한 관련 이해관계자에게 제공될 수 있습니다.

조직은 AI 시스템 영향 평가의 결과를 위험 평가(6.1.2 참조)에 반영해야 합니다. 표 A.1의 A.5에서는 AI 시스템의 영향을 평가하기 위한 통제를 제공합니다.

참고: 일부 맥락(예: 안전 또는 프라이버시와 관련된 AI 시스템)에서는 조직이 전반적인 위험 관리 활동의 일환으로 특정 분야별 AI 시스템 영향 평가(예: 안전, 프라이버시 또는 보안 영향)를 수행해야 할 수 있습니다.

6.2 AI 목표 및 목표 달성을 위한 계획

조직은 관련 기능 및 수준에서 AI 목표를 수립해야 합니다. AI 목표는 다음을 만족해야 합니다:

- a) AI 정책(5.2 참조)과 일치;
- b) 가능하다면 측정 가능할 것;
- c) 적용 가능한 요구 사항을 고려할 것;
- d) 모니터링될 것;
- e) 전달될 것;
- f) 적절히 업데이트될 것;
- g) 문서화된 정보로 제공될 것.

AI 목표를 달성하기 위한 계획을 세울 때, 조직은 다음을 결정해야 합니다:

- 수행할 내용;
- 필요한 자원;
- 책임자;
- 완료 시점;
- 결과를 평가하는 방법.

참고: 위험 관리와 관련된 AI 목표의 비독점적 목록은 부록 C에 제공됩니다. 책임 있는 AI 시스템 개발 및 사용을 위한 목표 식별과 목표 달성을 위한 조치와 관련된 통제 목표와 통제 사항은 표 A.1의 A.6.1 및 A.9.3에 제공됩니다. 이러한 통제 사항의 구현 지침은 B.6.1 및 B.9.3에 제공됩니다.

6.3 변경 계획

조직이 AI 경영 시스템에 대한 변경이 필요하다고 판단할 때, 해당 변경은 계획된 방식으로 수행되어야 합니다.

7 지원

7.1 자원

조직은 AI 경영 시스템의 수립, 구현, 유지 및 지속적 개선에 필요한 자원을 결정하고 제공해야 합니다.

참고: AI 자원에 대한 통제 목표와 통제 사항은 표 A.1의 A.4에 제공됩니다. 이러한 통제 사항의 구현 지침은 B.4 조항에 제공됩니다.

7.2 역량

조직은 다음을 수행해야 합니다:

- AI 성과에 영향을 미치는 업무를 수행하는 인원의 필요한 역량을 결정;
- 해당 인원이 적절한 교육, 훈련 또는 경험을 바탕으로 역량을 갖추도록 보장;
- 필요한 경우, 필요한 역량을 획득하기 위한 조치를 취하고 조치의 효과를 평가.

역량을 증명하기 위한 적절한 문서화된 정보가 제공되어야 합니다.

참고 1: 필요한 전문 지식을 고려한 인적 자원에 대한 구현 지침은 B.4.6에 제공됩니다.

참고 2: 적용 가능한 조치에는 예를 들어 현재 고용된 인원에게 대한 교육 제공, 멘토링, 재배치, 또는 역량을 갖춘 인원의 채용 또는 계약이 포함될 수 있습니다.

7.3 인식

조직의 통제 하에 업무를 수행하는 인원은 다음 사항을 인식해야 합니다:

- AI 정책(5.2 참조);
- AI 경영 시스템의 효과성에 대한 자신의 기여, 향상된 AI 성과의 이점 포함;
- AI 경영 시스템 요구 사항을 준수하지 않았을 때의 영향.

7.4 의사소통

조직은 AI 경영 시스템과 관련된 내부 및 외부 의사소통을 다음을 포함하여 결정해야 합니다:

- 무엇을 의사소통할 것인지;
- 언제 의사소통할 것인지;
- 누구와 의사소통할 것인지;
- 어떻게 의사소통할 것인지.

7.5 문서화된 정보

7.5.1 일반

조직의 AI 경영 시스템에는 다음이 포함되어야 합니다:

- a) 이 문서에서 요구하는 문서화된 정보;
- b) 조직이 AI 경영 시스템의 효과성을 위해 필요하다고 판단한 문서화된 정보.

참고: AI 경영 시스템에 대한 문서화된 정보의 범위는 조직의 규모와 활동, 프로세스, 제품 및 서비스 유형, 프로세스의 복잡성과 상호작용, 인원의 역량에 따라 조직마다 다를 수 있습니다.

7.5.2 문서화된 정보의 생성 및 업데이트

문서화된 정보를 생성하고 업데이트할 때, 조직은 적절한 다음 사항을 보장해야 합니다:

- 식별 및 설명(예: 제목, 날짜, 작성자 또는 참조 번호);
- 형식(예: 언어, 소프트웨어 버전, 그래픽) 및 매체(예: 종이, 전자);
- 적합성과 적절성을 위한 검토 및 승인.

7.5.3 문서화된 정보의 관리

AI 경영 시스템 및 이 문서에서 요구하는 문서화된 정보는 다음을 보장하기 위해 관리되어야 합니다:

- a) 필요할 때와 장소에서 사용 가능하고 적합함;
- b) 적절히 보호됨(예: 기밀성 손실, 부적절한 사용 또는 무결성 손실로부터).

문서화된 정보의 관리를 위해 조직은 다음 활동을 적절히 다루어

야 합니다:

- 배포, 접근, 검색 및 사용;
- 보관 및 보존(가독성 보존 포함);
- 변경 관리(예: 버전 관리);
- 보유 및 처분.

조직이 AI 경영 시스템의 계획 및 운영을 위해 필요하다고 판단한 외부 출처의 문서화된 정보는 적절히 식별되고 관리되어야 합니다.

참고: 접근은 단순히 문서화된 정보를 볼 수 있는 권한에 대한 결정이거나, 정보를 보고 변경할 수 있는 권한과 권위를 의미할 수 있습니다.

8 운영

8.1 운영 계획 및 통제

조직은 요구 사항을 충족하고 6장에서 결정된 조치를 구현하기 위해 필요한 프로세스를 계획, 구현 및 통제해야 합니다.

이를 위해:

- 프로세스에 대한 기준을 설정;
- 기준에 따라 프로세스 통제를 구현.

조직은 AI 경영 시스템의 운영과 관련된 통제(예: AI 시스템 개발 및 사용 생애 주기 관련 통제)를 6.1.3에 따라 결정된 대로 구현해야 합니다.

이러한 통제의 효과성을 모니터링하고, 의도한 결과가 달성되지 않을 경우 시정 조치를 고려해야 합니다. 부록 A에는 참조 통제가 나와 있으며, 부록 B에는 그에 대한 구현 지침이 제공됩니다.

프로세스가 계획대로 수행되었음을 확신할 수 있도록 필요한 범위까지 문서화된 정보가 제공되어야 합니다.

조직은 계획된 변경을 통제하고, 의도하지 않은 변경의 결과를 검토하여 필요할 경우 부정적인 영향을 완화하기 위한 조치를 취해야 합니다.

조직은 AI 경영 시스템과 관련된 외부 제공 프로세스, 제품 또는 서비스가 통제되도록 해야 합니다.

8.2 AI 위험 평가

조직은 6.1.2에 따라 계획된 간격으로 또는 중요한 변경이 제안되거나 발생할 때 AI 위험 평가를 수행해야 합니다.

모든 AI 위험 평가 결과에 대한 문서화된 정보를 보유해야 합니다.

8.3 AI 위험 처리

조직은 6.1.3에 따라 AI 위험 처리 계획을 구현하고 그 효과를 검증해야 합니다.

위험 평가에서 새로운 위험이 식별되어 처리가 필요한 경우, 이러한 위험에 대해 6.1.3에 따른 위험 처리 프로세스를 수행해야 합니다.

위험 처리 계획에 정의된 위험 처리 옵션이 효과적이지 않은 경우, 이러한 처리 옵션을 검토하고 6.1.3에 따른 위험 처리 프로세스를 다시 수행하여 위험 처리 계획을 업데이트해야 합니다. 모든 AI 위험 처리 결과에 대한 문서화된 정보를 보유해야 합니다.

8.4 AI 시스템 영향 평가

조직은 계획된 간격으로 또는 중요한 변경이 제안될 때 6.1.4에 따라 AI 시스템 영향 평가를 수행해야 합니다. 모든 AI 시스템 영향 평가 결과에 대한 문서화된 정보를 보유해야 합니다.

9 성과 평가

9.1 모니터링, 측정, 분석 및 평가

조직은 다음을 결정해야 합니다:

- 모니터링 및 측정이 필요한 사항;
- 유효한 결과를 보장하기 위해 필요한 모니터링, 측정, 분석 및 평가 방법(적용 가능한 경우);
- 모니터링 및 측정이 수행될 시기;
- 모니터링 및 측정 결과를 분석하고 평가할 시기.

문서화된 정보가 결과의 증거로 제공되어야 합니다.

조직은 AI 경영 시스템의 성과와 효과성을 평가해야 합니다.

9.2 내부 감사

9.2.1 일반

조직은 AI 경영 시스템이 다음을 충족하는지 여부에 대한 정보를 제공하기 위해 계획된 간격으로 내부 감사를 수행해야 합니다:

a) 다음에 대한 적합성:

1. 조직의 AI 경영 시스템에 대한 자체 요구 사항;
2. 본 문서의 요구 사항;

b) 효과적으로 구현되고 유지되고 있는지 여부.

9.2.2 내부 감사 프로그램

조직은 빈도, 방법, 책임, 계획 요구 사항 및 보고를 포함하여 (내부) 감사 프로그램을 계획, 수립, 구현 및 유지해야 합니다.

감사 프로그램을 수립할 때, 조직은 관련 프로세스의 중요성과 이전 감사 결과를 고려해야 합니다.

조직은 다음을 수행해야 합니다:

- a) 각 감사에 대한 감사 목표, 기준 및 범위 정의;
- b) 감사 프로세스의 객관성과 공정성을 보장하기 위해 감사원을 선택하고 감사를 수행;
- c) 감사 결과를 관련 관리자에게 보고.

문서화된 정보가 감사 프로그램의 실행과 감사 결과에 대한 증거로 제공되어야 합니다.

9.3 경영 검토

9.3.1 일반

최고 경영진은 조직의 AI 경영 시스템의 지속적인 적합성, 충분성 및 효과성을 보장하기 위해 계획된 간격으로 검토해야 합니다.

9.3.2 경영 검토 입력

경영 검토에는 다음이 포함되어야 합니다:

- a) 이전 경영 검토에서 나온 조치의 상태;
- b) AI 경영 시스템과 관련된 외부 및 내부 문제의 변화;
- c) AI 경영 시스템과 관련된 이해관계자의 요구와 기대의 변화;
- d) AI 경영 시스템 성과에 대한 정보, 다음 항목에 대한 경향 포함:
 - 1. 부적합 및 시정 조치;
 - 2. 모니터링 및 측정 결과;
 - 3. 감사 결과;
- e) 지속적 개선의 기회.

9.3.3 경영 검토 결과

경영 검토의 결과에는 지속적 개선 기회와 AI 경영 시스템 변경 필요성과 관련된 결정이 포함되어야 합니다.

문서화된 정보가 경영 검토 결과의 증거로 제공되어야 합니다.

10 개선

10.1 지속적 개선

조직은 AI 경영 시스템의 적합성, 충분성 및 효과성을 지속적으로 개선해야 합니다.

10.2 부적합 및 시정 조치

부적합이 발생하면 조직은 다음을 수행해야 합니다:

a) 부적합에 반응하고, 적용 가능한 경우:

1. 이를 통제하고 수정하기 위한 조치를 취함;
2. 그로 인한 결과를 처리함;
 - b) 부적합의 원인을 제거하여 재발하거나 다른 곳에서 발생하지 않도록 하기 위한 조치의 필요성을 평가함;
3. 부적합을 검토;
4. 부적합의 원인을 파악;
5. 유사한 부적합이 존재하거나 발생할 가능성이 있는지 확인;
 - c) 필요한 조치를 구현;
 - d) 취한 시정 조치의 효과성을 검토;
 - e) 필요할 경우 AI 경영 시스템을 변경.

시정 조치는 발생한 부적합의 영향에 적절해야 합니다.

문서화된 정보는 다음에 대한 증거로 제공되어야 합니다:

- 부적합의 성격과 그에 따른 조치;
- 시정 조치의 결과.